

Incident Response Team

Report №5
Solar-Winds Supply-Chain Attack
2020

08.11.2025

Almaty

Table of Contents

Introduction	3
Attack Steps	4
1. Reconnaissance; choose the target	4
2. Compromise of the build or update system	4
3. Distribution via normal updates	4
4. Backdoor activation and stealth	4
5. Command-and-control (C2) and staged tooling.....	4
6. Lateral movement and credential theft.....	4
7. Data collection and exfiltration.....	4
8. Long dwell time and cleanup avoidance	4
Victims and Assets	5
Victims.....	5
Damage.....	5
Defense Recommendations	6
Hunt with SIEM	6
Watch for Unauthorized Changes.....	6
Stop Data Theft with DLP.....	6
Role-Based Conclusion	7
How the attack could have been prevented?	7
How the damage could have been minimized?	7
References	8

Introduction

In today's world, even the biggest organizations rely on trust. We trust that the software we install and update is safe; that it comes from reliable companies who protect their code. But in 2020, that trust was quietly broken by one of the most shocking cyberattacks in history: the *SolarWinds Supply-Chain Attack*.

Unlike attacks that target one company or one person, this one used a much smarter path. Instead of breaking into systems directly, the attackers went after a trusted software vendor - SolarWinds. By secretly adding malicious code into the company's regular software updates, they turned a trusted tool into a hidden weapon.

When thousands of SolarWinds customers installed those updates, they unknowingly opened the door for hackers. Through that single doorway, the attackers gained access to government networks, large corporations, and other critical systems around the world.

The SolarWinds case teaches us a simple but powerful lesson: sometimes, danger doesn't come from obvious threats or suspicious emails. It can come from the very tools we rely on every day. Understanding this attack helps us see how fragile digital trust can be - and why securing our software supply chain is now more important than ever.

Attack Steps

1. Reconnaissance; choose the target (T1595: Active Scanning)
 - **What they did:** attackers studied SolarWinds' systems and processes to find how and where to insert malicious code.
 - **Impact:** this careful research let them plan an attack that would reach many organizations at once, because SolarWinds was a trusted vendor used widely.
2. Compromise of the build (T1195.002: Supply Chain Compromise)
 - **What they did:** the attackers gained access to SolarWinds' build environment and inserted malicious code into the Orion software builds (so the official product packages were trojanized).
 - **Impact:** the malicious code became part of the official software - it looked genuine because it was distributed and signed by SolarWinds.
3. Distribution via normal updates (T1204.002: User Execution)
 - **What they did:** SolarWinds' normal update mechanism distributed the compromised Orion updates to customers as routine patches.
 - **Impact:** thousands of organizations (including government and large companies) downloaded and installed the infected updates, giving attackers many entry points at once.
4. Backdoor activation and stealth (T1027: Obfuscated Files)
 - **What they did:** once installed, the malicious component (known as *Sunburst*) sat quietly for a short time then "phoned home" to attacker servers using carefully disguised network requests.
 - **Impact:** because the traffic looked like normal web/DNS traffic and the backdoor delayed activity, it avoided easy detection for weeks to months.
5. C2 and staged tooling (T1071.002: Web Protocols)
 - **What they did:** after contact, attackers sent commands and additional tools to infected systems - enabling them to run reconnaissance code, capture credentials, and install more powerful malware.
 - **Impact:** attackers could explore the internal network, escalate privileges, and prepare targeted thefts of high-value data.
6. Lateral movement and credential theft (T1550.002: Pass the Hash)
 - **What they did:** attackers used harvested credentials and legitimate admin tools to move from the infected Orion server to other systems (servers, email, cloud consoles).
 - **Impact:** by moving laterally and using real credentials, attackers accessed sensitive systems and data while blending into normal activity.
7. Data collection & Exfiltration (T1005 & T1041: Data from Local System; Exfiltration over C2)
 - **What they did:** attackers collected sensitive files and information and sent it back to their servers, using common web protocols to hide the activity.
 - **Impact:** confidential data from governments and corporations was copied and taken out of victim networks - this is the main loss (data breach, espionage, operational risk).
8. Long dwell time and cleanup avoidance (T1505.003: Web Shell)
 - **What they did:** the attackers stayed hidden for a long time and took steps to remove traces (e.g., deleting logs or using stealthy techniques), slowing detection and forensic work.
 - **Impact:** the longer attackers remained, the more damage and data loss could occur; cleanup and recovery became more difficult and costly.

Victims and Assets

Victims

The victims of the SolarWinds attack were not random individuals, but some of the most high-profile organizations in the world. The attack's nature, starting from a single infected software update, meant that any organization using the compromised SolarWinds Orion software was a potential victim. We can categorize them into 3 main groups:

1. **Government Agencies:** This was the most critical category. Major U.S. agencies were breached, including the Treasury, Justice, and Homeland Security departments, as well as the Pentagon.
2. **Large Corporations:** Many Fortune 500 companies were affected because they used SolarWinds to monitor their own large networks. Victims included major technology firms, telecommunications providers, and consulting giants.
3. **Security and IT Departments:** Within all the victim organizations, the IT and cybersecurity teams themselves were primary victims. The hackers used the very tools these teams relied on for visibility and security to spy on them, making their job of detecting the attack incredibly difficult.

Damage

- *Reputational*
 - For SolarWinds: The company's reputation as a trusted software vendor was shattered. Customers lost confidence in its products and its ability to secure its own systems.
 - For Victim Organizations: Major corporations and government agencies suffered a severe blow to their credibility. They were seen as vulnerable and unable to protect their most critical systems and data from a sophisticated threat.
- *Financial*
 - Victims incurred massive expenses in incident response, including hiring forensic experts, rebuilding infected networks, and implementing new security tools. SolarWinds itself faced a steep drop in its stock price and millions of dollars in legal fees and fines.
- *Operational*
 - Thousands of work hours were lost as IT teams worked around the clock to identify the breach, disconnect the compromised software, and clean their systems. This diverted resources from normal business operations.
- *Security*
 - The theft of classified government data and sensitive corporate secrets represents a catastrophic security failure. This information in the hands of adversaries has long-term implications for national and economic security. The attack also led to the erosion of trust.

Defense Recommendations

The core lesson from threats like SolarWind becoming a trojan is to always double-check. Malware may hide itself in a trusted and widely-used software – so even if trusted every kind of software, new or updated, must be, unfortunately, monitored closely.

Hunt with SIEM

A SIEM (security information and event management) system is like a security guard that reads all computer logs, looking for anything unusual. Using a SIEM results in getting alerts if a trusted programs (like SolarWinds Orion) suddenly starts sending huge amounts of data to a new, unknown server on the internet.

Watch for Unauthorized Changes

Actively monitor user and system directories for any strange changes. Set up alerts for any new, powerful user accounts being created or for unusual login times from system administrators. This could have caught the attackers if they tried to create backdoor accounts

Stop Data Theft with DLP

A Data Loss Prevention system acts like a smart filter that watches for sensitive data trying to leave your network. Configure DLP to block or alert if large amounts of secret documents or intellectual property are being uploaded to an external server, especially by a program that doesn't do that.

Role-Based Conclusion

My role: tech employee, pentester.

As a *pentester* I focus on mimicking and tracing back the attacker's doings. I would...

How the attack could have been prevented?

- **Test the “Unhackable”:** I would specifically test the software we trust the most, like our network monitoring tools. I'd try to sneak a fake backdoor into a software update process to see if our defenses notice.
- **Assume Breach:** I would operate on the rule "never trust, always verify." I'd test if I can move from a low-level system (like a monitoring server) to our most sensitive areas (like finance or R&D servers). This checks if our network segmentation is strong enough.

How the damage could have been minimized?

- **Set Better Tripwires:** After my test, I'd work with the Blue Team to create alarms for the specific tricks I used. For example: “Alert if the SolarWinds server tries to connect to a new, unknown internet address” or “Alert if it suddenly starts reading sensitive files it doesn't need.”
- **Practice the “WHAT THE HEEEEELL WE’VE BEEN HACKED!!!” Plan:** I would help run a drill simulating a compromised software vendor. The goal is to see how fast we can find and disconnect the bad software across the whole company. Speed is everything to minimize damage.

References

1. “Solar Winds Cyber Attack”, Fortinet, <https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack>
2. “SolarWinds Cyber Case study”, Ollis/Akers/Arney, https://ollisakersarney.com/wp-content/uploads/2021/10/Cyber_Case_Study_-_SolarWinds_Supply_Chain_Cyberattack.pdf
3. “SolarWinds Attack: Stages, Implications, and Mitigation Strategies in the Cyber Age”, Telkom University, https://www.researchgate.net/publication/385406207_SolarWinds_Attack_Stages_Implications_and_Mitigation_Strategies_in_the_Cyber_Age
4. “SolarWinds Cyber Case study”, Ollis/Akers/Arney, <https://www.security.com/threat-intelligence/sunburst-supply-chain-attack-solarwinds>